



NETWORK SECURITY | MODULE 3

Security Goals, Authorization and Access Control

Lesson 4 – Security and Authorization

Lesson 7 – Multi Level Model of Security



CIA · Risk analysis · Threats & vulnerabilities · Authentication · Passwords · Firewalls · IDS · Auditing



LESSON 4: SECURITY AND AUTHORIZATION

- 1 **Goals of Computer Security**
Integrity, confidentiality, availability
- 2 **Security Problem & Risk Analysis**
Assets, threats and impact
- 3 **Threats and Vulnerabilities**
Breaches, method-opportunity-motive
- 4 **User Authentication**
Know, have, are; MAC and DAC; tokens

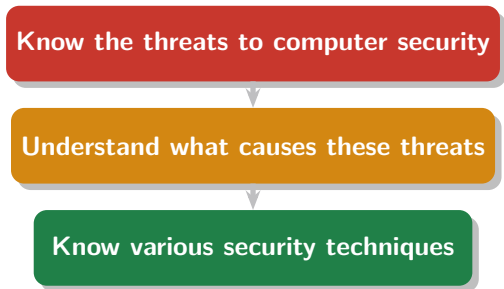
LESSON 7: MULTI LEVEL MODEL OF SECURITY

- 5 **Access & Password Controls**
Access, passwords, privileged users, accounts
- 6 **Protection & Backup**
Data, resources, sensitive systems
- 7 **Firewalls, Encryption & IDS**
Packet filters, proxies, intrusion detection
- 8 **Controls, People & Auditing**
Software, hardware, physical, personnel



Lesson 4

Security and Authorization



The big question

How do we decide **what** to protect, **from whom**, and **how**, and then make sure only the **right people** get in?

- Goals: **C, I, A**
- Risk analysis in 3 steps
- Threats vs. vulnerabilities
- Authentication and authorization

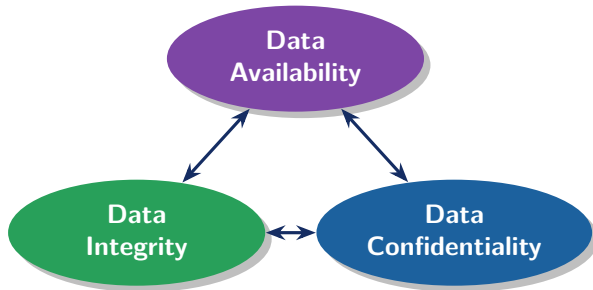


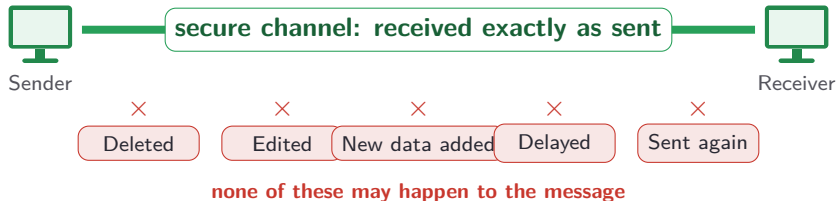
Figure 1: they depend on each other

- The goals of computer security are **integrity**, **confidentiality** and **availability** of the information managed by the system
- The three are **related**: improving one can weaken another

Example of the tension

Locking data away very tightly improves confidentiality, but it can **hurt availability** for the people who need it.

Goal 1: Integrity

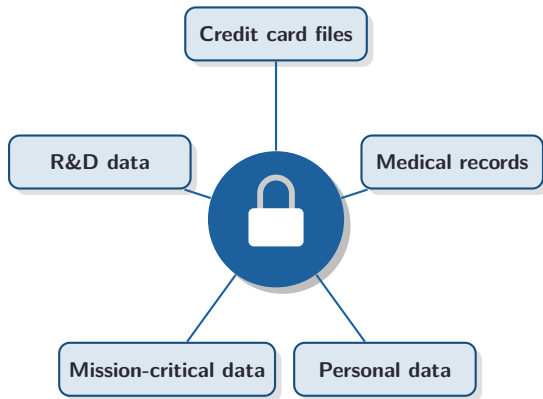


Definition

Data sent through the secure channel is **not altered or tampered** with by others.

Note

Integrity does **not** stop a third party from *viewing* the data; it only guarantees nobody *modified* it.



Definition

When data travels from source to destination, **nobody except the intended person** can view it.

- A network with no confidentiality is **not secure**
- Minimum requirement: the mail you send a friend is **not read by anyone else**
- If people cannot trust e-mail to be confidential, they **never use it**



Definition

The system is **accessible to authorized persons at appropriate times**.

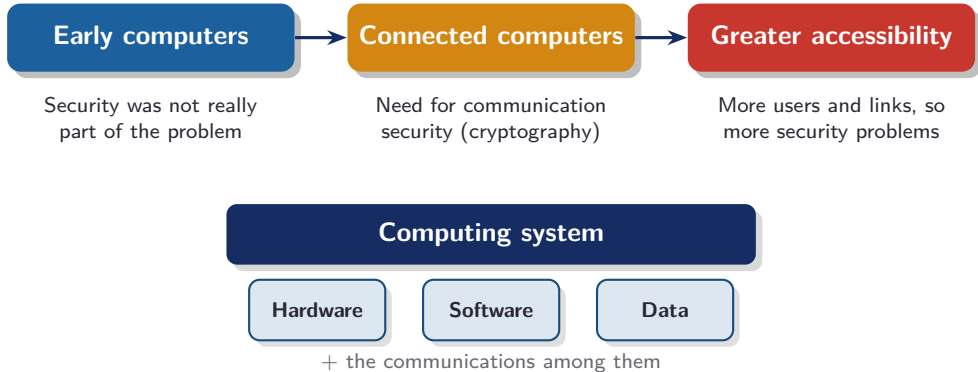
Balance

There is no point making a system so secure that **no user can access** the data they need to do their jobs.

A computer system is available if...

- ✓ The response time is acceptable
- ✓ There is a fair allocation of resources
- ✓ Fault tolerance exists
- ✓ It is user friendly
- ✓ Concurrency and deadlock control exist

The Security Problem



Computer security tries to ensure the **confidentiality, integrity and availability** of these components. Attackers exploit **vulnerabilities** through interception, interruption, modification and fabrication.



What do you need to protect?

What do you need to protect it from?

How do you protect it?

Risk analysis

The process of **examining all of your risks** and **ranking them by severity**.

Three major steps

Identify
the assets



Identify
the threats



Identify
the impact

Step 1: Identifying the Assets



Hardware

CPUs, boards, terminals, printers, disks, routers, hubs, servers

Software

Source and object programs, OS, utilities, fire-wall and IDS software

Data

Online data, archives, backups, audit logs, databases, data in transit

People

Users and the people needed to run the systems

Documentation

Programs, hardware, systems, local admin procedures

Supplies

Paper, forms, ribbons, diskettes, magnetic media

List all the things that are subject to security threats.



ASSET RECORD: Mail Server

Designated owner IT Manager

Support system Critical application

Location Server room B

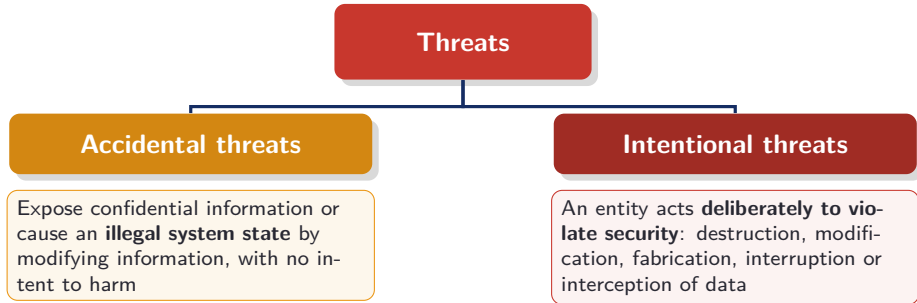
From the asset list, build an **inventory** with these components for **each asset**:

- ① A **designated owner**
- ② A **general support system** or **critical/major application**
- ③ Its **physical/logical location**

Why?

You cannot protect what you do not know you have, and every asset needs **someone responsible** for it.

Step 2: Identifying the Threats



Possible threats to a computer system (think in terms of C, I and A)

Unauthorized access

threatens Confidentiality

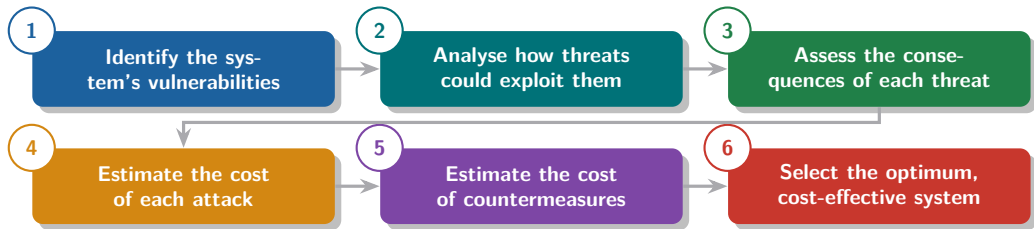
Disclosure of information

threatens Confidentiality

Denial of service

threatens Availability

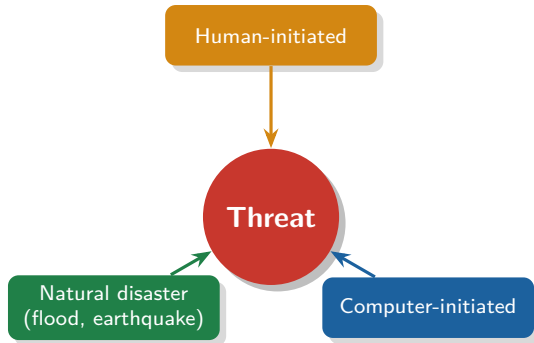
Step 3: Identifying the Impact



A threat that materializes can cause one or more impacts

- Infringement of **privacy**
- **Financial** loss
- **Disruption** of activities

What Is a Threat?



Definition

A set of circumstances that has the **capability of causing loss or harm** to the computer system.

- Multiprogramming increased what needs protection: system software, memory, shared I/O devices (disks, printers, tape drives), shared programs, networks and data
- A threat can be **accidental** or **deliberate**

Four Kinds of Security Breach



Interruption

What: An asset becomes lost, unavailable or unusable

Examples: Destroy hardware, delete a program or file, OS malfunction

Modification

What: Unauthorized party accesses *and* tampers with an asset

Examples: Change database values, alter a program, modify hardware

Interception

What: An unauthorized person, program or computer gains access

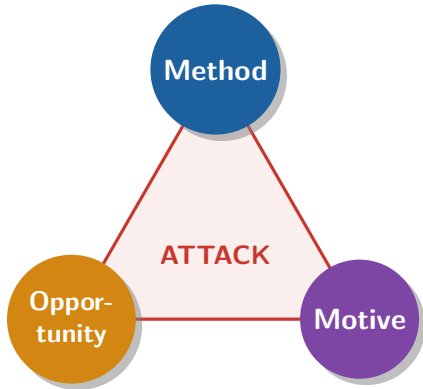
Examples: Illicit copying of programs or data, wiretapping

Fabrication

What: Counterfeit objects are created in the system

Examples: Spurious transactions, altered existing database

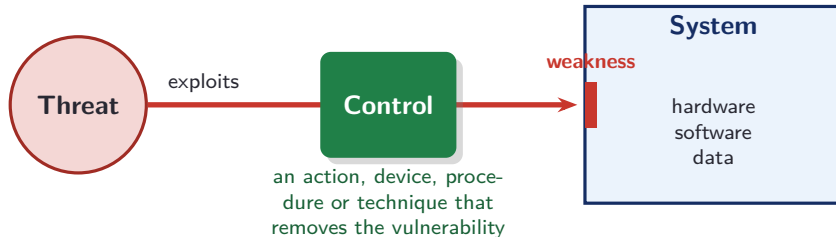
What Does an Attacker Need? M–O–M



- **Method:** the tools, skills and knowledge
- **Opportunity:** the right time and the right access
- **Motive:** the reason to carry out the attack

Defender's view

Take away **any one** of the three and the attack cannot happen. Limiting *opportunity* is usually the easiest.



Vulnerability

A **weakness** in the system that threats can exploit. It does no harm **until exploited**. It can lie in **procedures, design or implementation**.

Control

A **protective measure** that limits or **eliminates** a vulnerability, and so **blocks** the threat.



No security training

Poor password management

Passwords sent in clear text

Weak authentication

Unprotected public network links

Known software flaws

Unsupervised external staff

No security policy

Poor cable joints

No audit trail

Wrong access rights

Dial-up connections

Also: inadequate recruitment procedures, insufficient preventive maintenance, inadequate system management.



Software vulnerabilities

Deleted or stolen (pirated) software, unexpected behaviour and flaws, program errors, altered but still running

Hardware vulnerabilities

Interruption (denial of service), modification, fabrication (substitution), interception (theft)

Data vulnerabilities

Interruption (loss of data), interception, modification and fabrication of data

Human vulnerabilities

Break-ins, virus generation, security violations, inadequate training

User Authentication: Three Qualities



Something you **KNOW**

Password, PIN, pass phrase, secret handshake



Something you **HAVE**

Identity badge, physical key, driving licence, uniform



Something you **ARE**

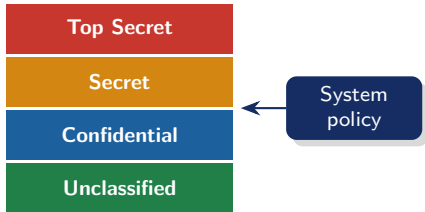
Fingerprint, face recognition, voice recognition

Combine for stronger authentication

Two or more methods together give **more solid** authentication, e.g. an **identity card + PIN** (have + know), as at an ATM.

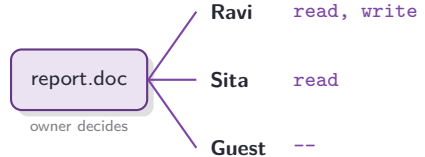


Mandatory Access Control (MAC)

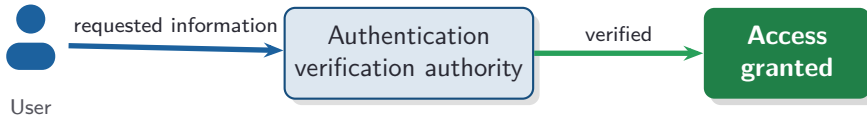


A policy for systems with **highly secret or sensitive** information. Access follows fixed labels set by the **system**. Typically used by **government agencies**.

Discretionary Access Control (DAC)



Uses the **identity of the user or group**.
Discretionary: the administrator decides **who** has access and **what type**: create, write, read, update or delete.



Fingerprint scan

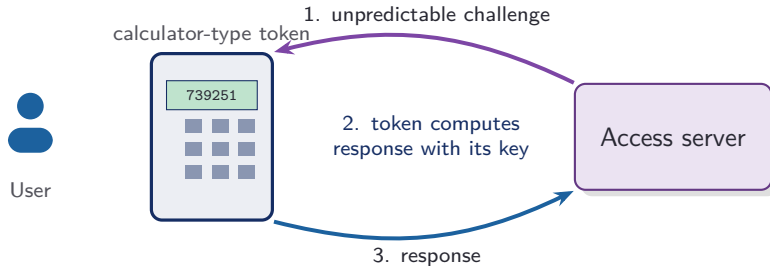
Iris scan

Hand geometry

biometric authentication: identified by physical characteristics

- Authentication occurs when a user **provides the requested information** to a verification authority
- The **traditional** method is a **password**
- For more **reliability**, use biometrics: the user is identified by who they physically *are*, not just digitally

Hardware Token: Challenge and Response

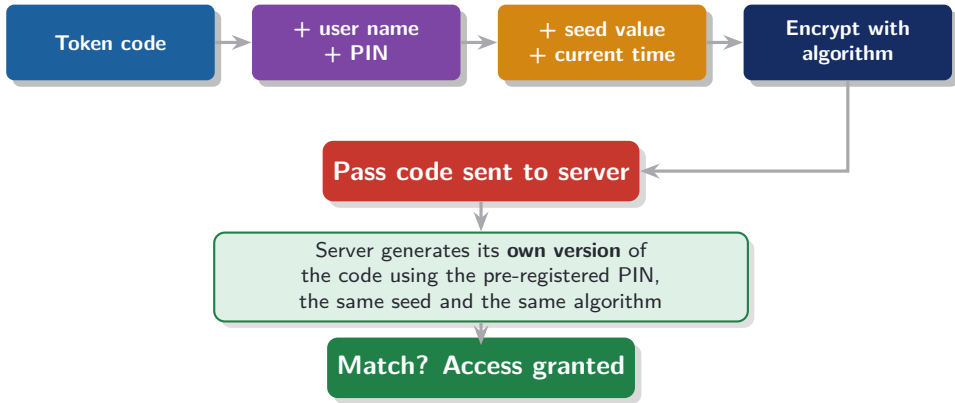


Authentication token

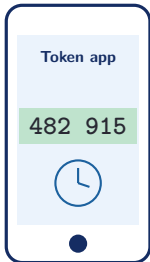
A **portable device** used for authenticating a user.

- Token and server hold **identical security keys or algorithms**
- The user types the challenge into the token and sends back the response

Hardware Token: Time-Based



The token and the server use an **identical algorithm**. Because the current time is part of the input, each pass code is **valid only briefly**.



software, not a device

runs on: Palm Pilot,
Palm PC, mobile phone

Software token

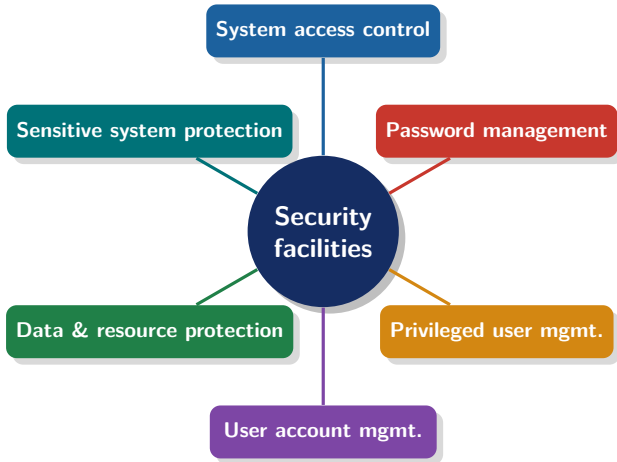
An authentication process using **portable devices** (Palm Pilot, Palm PC, wireless telephone) that carry the **embedded software**.

- Chosen when an organization does **not wish to buy hardware tokens**
- Today's authenticator apps on smartphones are modern software tokens



Lesson 7

Multi Level Model of Security



- Security controls should be installed and maintained on **each computer system or node**
- Goal: stop **unauthorized users** entering the system and stop **unauthorized access** to data
- Software and resources are reachable **only after authentication**



Who can get in

- Access to memory, storage, sensitive utilities and files is on a **“need-to-use” basis**
- Access-control software must restrict access; **avoid common passwords** like “administrative”, “president”, “game”
- Access guidelines are **documented and implemented**
- Each user gets a **unique user ID**

What the system must do

- **Encrypt** stored passwords with proven algorithms
- **Auto time-out** for inactive terminals
- Log an **audit trail** of sensitive actions, and protect it from change or deletion
- Log and monitor **remote users**
- Automate security start-up and shutdown
- Protect sensitive OS files with proven tools

Password Management Rules



8+

characters minimum, no leading or trailing blanks

90

days: change at least this often

30

days for sensitive systems

3

failed log-ons, then revoke the user ID

new

must differ from existing passwords

###

always stored encrypted, never shown

Also

Do not share, display or print passwords · avoid easy-to-guess passwords · resist **dictionary attacks** and known cracking tools

Weak vs. Strong Passwords



Weak: guessed in seconds

password

dictionary word

ravi1990

name + birth year

12345678

simple sequence

admin

common default

Strong: follows the rules

Tr#9vLq!2x

mixed and long

My2Cats&Tea

memorable phrase

Vz7\$kP0-mW

random characters



weak

length + mix of upper, lower, digits, symbols + no personal info

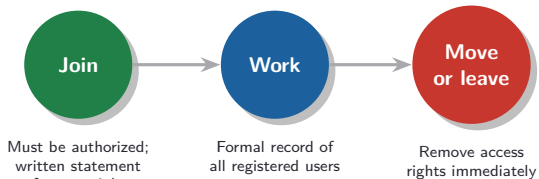
strong



Privileged user management

- Privileges only on a **need-to-use** basis
- Log-in available **only from the console**
- Maintain an **audit log**

User account life cycle



Periodic review: remove redundant accounts and unneeded rights. Never **reissue** a redundant account to another user.



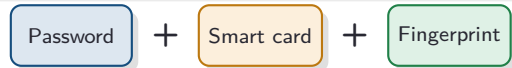
Data and resource protection

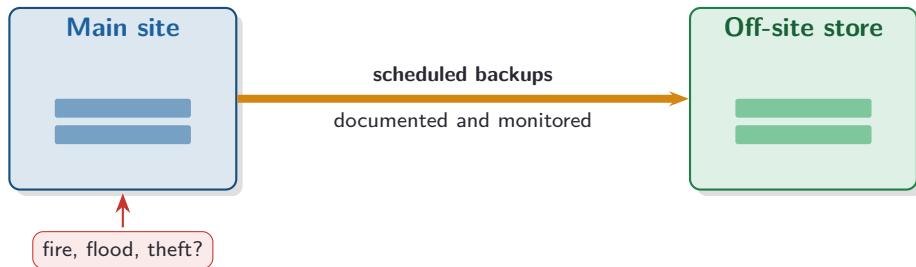
- Every piece of information gets an **owner** responsible for its integrity
- Assignment of responsibility is **formal**
- **Top management** supervises the whole allocation process



Sensitive system protection

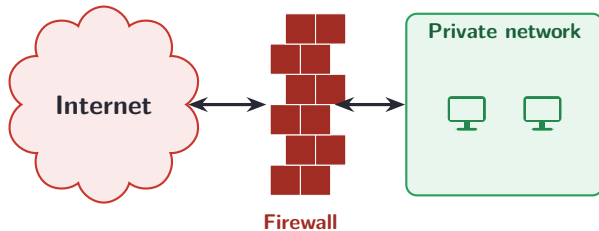
- Security tokens, smart cards and biometrics (iris, fingerprint) **complement passwords**
- **Encryption** protects the integrity and confidentiality of sensitive data





Keep up-to-date backups of critical items

Data files · utilities and programs · databases · operating system code · **encryption keys** · documentation · full and incremental backups on a schedule

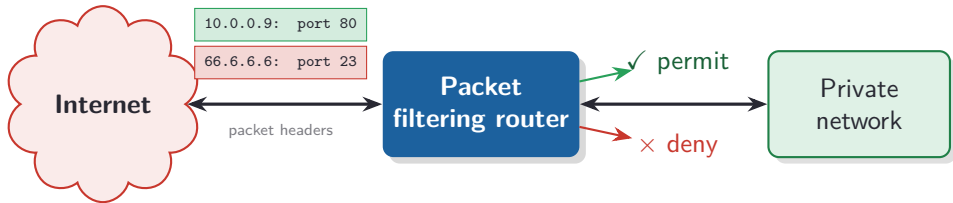


- **All packets** entering the network must pass through this point
- A modern firewall is a **system of applications and hardware** working together
- It combines:

Packet filtering

NAT

Proxy services

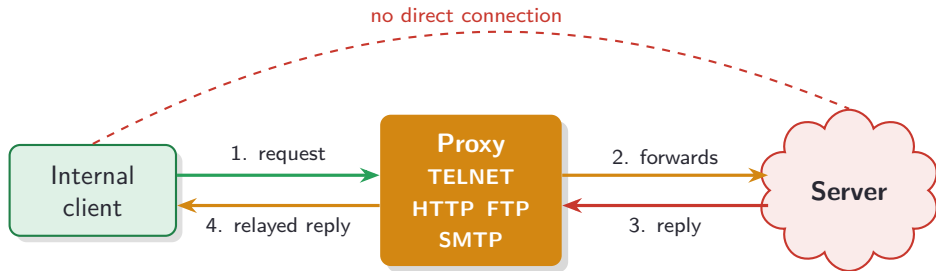


How it works

Looks at the **header information** of each packet and **permits or denies** it based on simple rules.

- The **first type** of firewall used by many organizations
- Usually implemented on a **router**
- Fast, but sees only headers, not content

Proxy Server (Application Gateway)

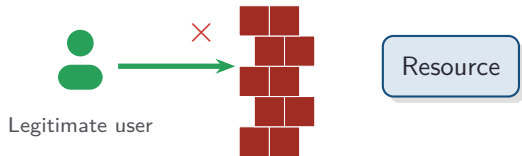


- Software that **intercepts** traffic destined for a given application and acts as a **man-in-the-middle**
- The internal client **never connects directly** to the external server
- Can make decisions based on **more than the header**, so it is more secure than a pure packet filter



- 1 All traffic, inside↔outside, passes through it
- 2 Only traffic authorized by the local policy passes
- 3 The firewall itself is immune to penetration
- 4 Uses various access-control methods
- 5 Service control: which Internet services are used
- 6 Direction control: which way a service request flows
- 7 User control: access based on permissions
- 8 Behaviour control: stops malpractice on secured data
- 9 Must itself be strong, or it is useless

Inbound data is checked to be from an **authenticated user**; outbound data is checked to be going to an **authenticated person**.



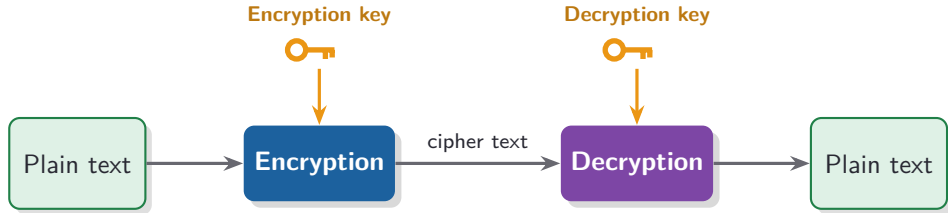
misconfigured rule blocks the user; slow firewall adds **latency**

Negative impacts

- **Improper configuration** blocks access to desired resources
- An ordinary **multi-homed PC** used as a firewall may be too slow, causing **latency**

Two general methods

Most firewalls are variations of **packet filtering** or **proxy servers (application gateways)**.



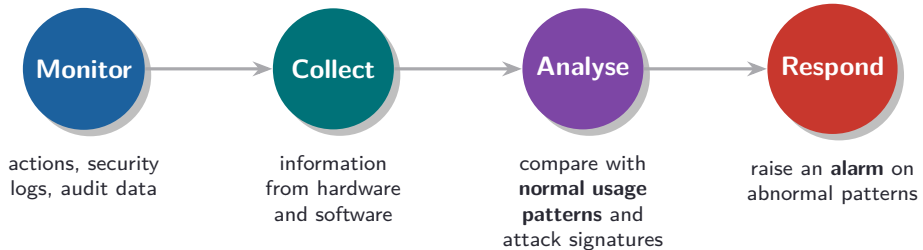
Why encryption matters

- **Central** to all security mechanisms
- Gives **confidentiality** of data
- Some protocols rely on it for **availability**

The cost

Encrypted data is **bigger**, so it needs more **bandwidth**, and devices need extra power to encrypt and decrypt.

Intrusion Detection System (IDS)



What an IDS is

A combination of **hardware and software** that monitors and analyses activity to **detect attacks or intrusions**. Some respond automatically; some use scanners for vulnerability analysis.

What an IDS cannot do

It **cannot stop crime**. It can only help prevent it and **provide evidence** for investigation.



Software controls

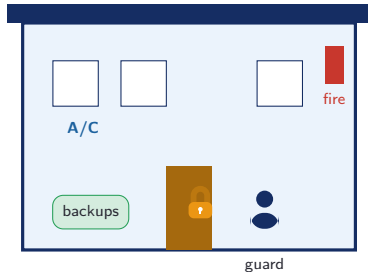
Internal program controls
OS controls
Development controls

Hardware controls

Locks or blocks
limiting access
Hardware or smart-
card encryption
Devices for user
authentication
Control of access
to storage media

Policies

Security policies and
procedures must be
properly implemented
to ensure their proper use



Easy to implement, effective and less costly

- Locks on doors; **guards** at entry and exit points
- Backup copies of critical software and data
- Access control and media control
- Precautions against **water and fire** damage
- Air conditioning
- Site planning that minimizes **natural disaster** risk



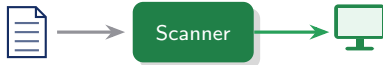
System security

International security standards: most vendors now build their security facilities to these standards.

Standards
built in

Computer virus controls

- Keep **updated** virus protection and detection software
- Scan **internal and external** drives regularly
- Screen all diskettes and software with a virus scanner **before loading**

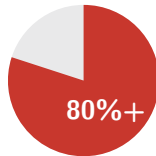




Definition

Everything involving **employees**, who are potential elements of security breaches: hiring, training, monitoring them, and handling their departure.

Most breaches are caused by **people**, and the most common perpetrators are the **legitimate users** of the system.



of incidents are due to **internal users**



```
security.log

09:02 ravi login OK
09:15 sita login OK
02:11 admin login FAIL
02:11 admin login FAIL
02:12 admin login FAIL
02:14 ravi login from 3 places
03:00 shutdown db-server
```

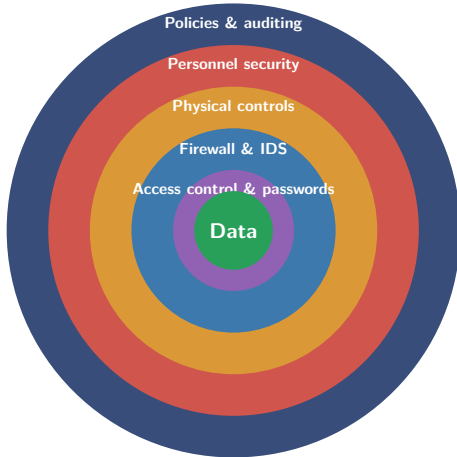
RED FLAGS

- A **tedious** process that needs a good eye for detail
- Track everyone who **logs on and off**
- Audit movement of **critical files**, attempted deletions, and access to mission-critical data

Red flags

Multiple bad log-on attempts · one account logging in from many places at once · attempted shutdown of critical servers

An organization that skips its logs may be **unable to tell the legal agencies** that an incident really happened.



Defence in depth

No single control is perfect. Security works in **layers**: if an attacker gets past one, the next one is still there.

- Lesson 4 decides **what** to protect and **why**
- Lesson 7 gives the **facilities** to protect it at every level



Lesson 4: Security and Authorization

- Goals: integrity, confidentiality, availability
- Risk analysis: assets, threats, impact
- Threats, vulnerabilities and controls
- Method, opportunity, motive
- Know, have, are; MAC vs. DAC; tokens

Lesson 7: Multi Level Model of Security

- Access, password and account management
- Data, resource and sensitive system protection
- Backups, firewalls, encryption, IDS
- Software, hardware and physical controls
- Personnel security and auditing

Review questions

1. Discuss the goals of computer security.
2. What are the security problems and requirements?
3. Explain threats and vulnerabilities.
4. Write a short note on user authentication.
5. Explain security systems and facilities in network security.



- ① William Stallings, *Cryptography and Network Security*, PHI Publishers.
- ② Charlie Kaufman, Radia Perlman, *Network Security*, Pearson Education.
- ③ Bruce Schneier, *Applied Cryptography*, John Wiley & Sons.
- ④ Roberta Bragg, *Network Security: The Complete Reference*, TMH.

Thank You! Questions?